به‌نام آن‌که جان را فکرت آموخت

دانشگاه صنعتی شریف
دانشکدهٔ مهندسی کامپیوتر
درس امنیت داده و شبکه

تاریخ انتشار: سه‌شنبه ۱۴ مهر ۱۴۰۵
تاریخ تحویل: سه‌شنبه ۲۸ مهر ۱۴۰۵
مدرس: سولماز سلیمی

تمرین اول: setuid و آزمون کنترل دسترسی

انجام فردی نمره: ۰٪۵ مهلت: دو هفته

مسئله

سرویس خروجی‌گیری، مجموعه‌داده‌ها را در فایل‌هایی نگه می‌دارد که برای کاربران آزمایشی مستقیماً خواندنی نیستند و مالک آن‌ها حساب `exportsvc` است. چهار کاربر آزمایشی آلیس، باب، کارول و دیو از طریق یک برنامهٔ C با بیت `setuid` به سرویس درخواست می‌دهند. هنگام اجرای برنامه، UID واقعی متعلق به کاربر و UID مؤثر متعلق به `exportsvc` است. داشتن اختیار سیستم‌عامل برای بازکردن فایل، به‌تنهایی مجوز خواندن آن از طرف کاربر نیست.

سرویس خواندن مستقیم، ثبت کار، ساخت کار تازه از کار قبلی، اجرای کار و دریافت آرشیو را ارائه می‌کند. اسکلت برنامه، ذخیره‌سازی و ابزار آزمون آماده است. منطق کنترل دسترسی و تغییر اعتبارنامه‌ها را کامل کنید و یک آزمون‌گر مستقل بسازید که تصمیم و اثر عملیات را در دنباله‌های حالت‌مند بررسی کند.

بستهٔ دانشجو را می‌توانید از این پیوند بارگیری کنید.

سیاست

۱. خواندن داده و ثبت کار به مجوز فعلی همان داده نیاز دارد. هویت کاربر از UID واقعی فرایند گرفته می‌شود. درخواست، پارامتر UID ندارد. هر کار، درخواست‌کننده و دادهٔ هدف ثابتی دارد.

۲. ساخت کار تازه با `clone_job` فقط برای صاحب کار مبنا و با مجوز فعلی خواندن دادهٔ آن مجاز است. کار مبنا می‌تواند معلق یا تکمیل‌شده باشد. کار تازه همان داده را هدف می‌گیرد.

۳. هر یک از چهار کاربر آزمایشی می‌تواند اجرای هر کار را آغاز کند. پیش از نخستین خواندن داده، مجوز فعلی **درخواست‌کنندهٔ ذخیره‌شده در آن کار** بررسی می‌شود، نه مجوز اجراکننده. برای مثال، باب می‌تواند کار آلیس را اجرا کند؛ مجوز فعلی آلیس ملاک است. UID مؤثر helper جایگزین هویت درخواست‌کننده نیست. رد اجرا باید پیش از خواندن فایل داده رخ دهد و آرشیو یا رکورد تکمیل نسازد.

۴. هر اجرای ردشده دقیقاً یک رخداد `deny` و هر نخستین اجرای موفق دقیقاً یک رخداد `allow` دارد. رخداد شامل `job`، `requester`، `dataset` و `decision` است. فقط عملیات اجرای کار رخداد تولید می‌کند. خواندن مستقیم، ثبت کار، ساخت کار تازه و دریافت آرشیو، چه موفق و چه ردشده، هیچ رخدادی در این لاگ ندارند. اعطا و لغو مجوز و مشاهدهٔ وضعیت نیز رخداد اجرای کار تولید نمی‌کنند.

۵. آرشیو متعلق به درخواست‌کنندهٔ کار است. دریافت آرشیو فقط به مالکیت آن وابسته است. صاحب آرشیو حتی پس از لغو مجوز دادهٔ اصلی می‌تواند آن را دریافت کند. مجوز خواندن دادهٔ اصلی، مالکیت آرشیو شخص دیگری را ایجاد نمی‌کند.

۶. اجرای دوبارهٔ کار تکمیل‌شده، حتی پس از لغو مجوز داده، شناسهٔ آرشیو قبلی را برمی‌گرداند. خواندن، آرشیو و رخداد اجرای تازه تولید نمی‌شود. اجرای نخست و اجرای تکراری، با هر یک از چهار اجراکننده، نتیجهٔ موفق `allow` همراه شناسهٔ آرشیو دارند؛ پاسخ جداگانهٔ `already_done` تعریف نمی‌شود. در رابط پایتون، موفقیت با بازگشت شناسه و رد با استثنای `Denied` مشخص می‌شود. آرشیو همچنان متعلق به درخواست‌کننده است، نه اجراکننده.

۷. اعطا و لغو مجوز بر خواندن‌های آینده اثر دارند؛ مالکیت آرشیو موجود را تغییر نمی‌دهند. کار ردشده معلق می‌ماند و پس از اعطای مجوز می‌تواند موفق اجرا شود.

۸. همهٔ عملیات سرویس، پیش از چاپ پاسخ، توصیفگرهای داخلیِ فایل‌های حفاظت‌شده را می‌بندند و UID واقعی، مؤثر و ذخیره‌شده را به UID کاربر تبدیل می‌کنند. probe اعتبارنامه برای مشاهدهٔ رفتار توصیفگر باز، رابط تشخیصی جداگانه است.

خواسته‌ها

۱. **پیاده‌سازی C.** توابع `policy.c` و `credentials.c` را کامل کنید. اختیار `exportsvc` با اختیار درخواست‌کننده اشتباه نشود. تمام عملیات مجاز حفظ شوند. امضاها، headerها، موتور I/O، adapter، installer و آزمون‌های عمومی را تغییر ندهید.

۲. **شاهد اعتبارنامه.** خروجی واقعی probeها را برای دو کاربر ثبت کنید. در کاهش موقت، UID واقعی و مؤثر باید متعلق به کاربر و UID ذخیره‌شده متعلق به سرویس باشد؛ پس از بازیابی، UID مؤثر نیز به سرویس برگردد. کاهش دائمی باید هر سه UID را به کاربر تبدیل کند و بازیابی اختیار با `EPERM` رد شود. توصیفگر probe که پیش از کاهش دائمی باز شده، همچنان خواندنی است؛ بازکردن دوبارهٔ همان فایل باید با `EACCES` رد شود. تفاوت این دو رفتار را توضیح دهید.

۳. **مدل مستقل.** در `policy_model.py` ماشین حالتِ مجوزها، مالکیت کار، تکمیل کار، مالکیت آرشیو و لاگ اجرا را بنویسید. نتیجهٔ مورد انتظار از مدل محاسبه شود، نه از کَد تصمیم‌گیری یا وضعیت خصوصی سرویس.

۴. **آزمون حالت‌مند.** در `test_stateful.py` دست‌کم ۵۰۰ دنبالهٔ متمایز با طول ۵ تا ۲۰ عملیات بسازید. چهار کاربر و حداقل سه داده داشته باشید. همهٔ هفت عملیات در مجموعهٔ دنباله‌ها حضور داشته باشند: `read_dataset`، `enqueue`، `clone_job`، `run_worker`، `fetch_archive`، `grant` و `revoke`. مشاهدهٔ وضعیت با `snapshot` جزو عملیات دنباله نیست و در طول آن شمرده نمی‌شود. حداقل ۵۰ دنباله اجرای موفق و ۵۰ دنباله اجرای ردشدهٔ کار داشته باشند؛ شمارش فقط بر اساس پیش‌بینی مدل است، نه رفتار نسخهٔ مورد آزمون. دو دنباله متمایزند اگر فهرست مرتب عملیات و آرگومان‌هایشان یکسان نباشد؛ ترتیب کلیدهای شیء JSON اهمیتی ندارد. یک دنباله می‌تواند در هر دو گروه قرار بگیرد. تولید با بذر یکسان و fixture یکسان دقیقاً تکرارپذیر باشد؛ هر دنباله از وضعیت اولیهٔ تازه اجرا شود.

۵. **ضبط ویدیو.** یک ویدیوی ۳ تا ۵ دقیقه‌ای از اجرای پیاده‌سازی و آزمون‌ها ضبط کنید. منطق کنترل دسترسی و یک شاهد کاهش‌یافته را کوتاه توضیح دهید و ویدیو را همراه فایل‌های تمرین در کوئرا بارگذاری کنید.

۶. **مقایسهٔ تصمیم و اثر.** پس از هر عملیات، نتیجه، محتوا، کارهای ثبت‌شده، خواندن‌های پردازشگر، آرشیوها، وضعیت تکمیل و رخدادها را با مدل مقایسه کنید. شناسه‌های مدل و پیاده‌سازی را با نگاشت مقایسه کنید؛ برابر بودن شمارنده‌ها را فرض نکنید. تولید دنباله از مدل انجام شود، نه از وضعیت داخلی پیاده‌سازی. خواندن‌های پردازشگر فقط خواندن فایل داده هنگام نخستین اجرای موفق کار است و خواندن مستقیم را شامل نمی‌شود؛ این فهرست از `snapshot` گزارش می‌شود. محتوای آرشیو قطعی و برابر محتوای دادهٔ هدف در fixture است و زمان یا بخش تصادفی ندارد. همهٔ مشاهدات فقط از رابط backend، شامل پاسخ عملیات و `snapshot`، گرفته شوند، نه از فایل‌های داخلی.

۷. **کاهش شاهد.** برای هر ردهٔ ناسازگاری دست‌کم یک شاهد کاهش‌یافتهٔ بازتولیدپذیر با fixture، بذر، نتیجهٔ مورد انتظار و مشاهده‌شده تولید کنید. با حذف عملیات، شاهد را به حالت یک‌مینیمال برسانید: هیچ حذف تک‌عملیاتی که دنباله را معتبر نگه دارد نباید همان ردهٔ ناسازگاری را بازتولید کند. کوتاه‌ترین شاهد ممکن لازم نیست. ردهٔ ناسازگاری زوجِ نوع عملیاتی است که نخستین اختلاف در آن رخ داده و نام نخستین مؤلفهٔ متفاوت. ترتیب بررسی مؤلفه‌ها ثابت است: نتیجه، محتوا، کارها، خواندن‌ها، آرشیوها، تکمیل، رخدادها. نام‌های دقیق و قالب این زوج در `README.md` آمده است. نتیجه به تصمیم موفق یا رد و مقدار غیرمحتوایی پاسخ اشاره دارد؛ محتوا مقدار بازگشتی خواندن مستقیم یا دریافت آرشیو است. کارها و آرشیوها با ارجاع نمادینِ ثابت مشخص شوند؛ حذف یک عملیات نباید ارجاع‌های دیگر را جابه‌جا کند. دنباله معتبر است اگر هر ارجاع به کار یا آرشیوی اشاره کند که طبق مدل پیش از آن ساخته شده باشد. نتیجهٔ ردشده شیء تازه‌ای نمی‌سازد. هر حذف با fixture اولیهٔ تازه ارزیابی شود.

۸. **ارزیابی روی نسخه‌های ندیده.** آزمونگر باید backend صحیح را بپذیرد و سه نسخهٔ ناقصِ ارائه‌شده در زمان ارزیابی را رد کند. این نسخه‌ها از آزمون‌های عمومی سیاست عبور می‌کنند. دانشجو نسخهٔ ناقص نمی‌سازد. شرط وابسته به نام backend، نام کاربر خاص یا یک بذر خاص پذیرفته نیست.

اجرا و دامنه

بستهٔ دانشجو شامل کد C، adapter پایتون، installer، اسکلت مدل و آزمونگر، ۹ آزمون عمومی و راهنمای اجراست. از ماشین مجازی تازهٔ Ubuntu 24.04، Python 3.10 یا جدیدتر، کامپایلر C و Make استفاده کنید. کتابخانهٔ پایتون اضافی لازم نیست. حساب `exportsvc` غیر root است. installer و مدیریت fixture با `sudo` اجرا می‌شوند؛ عملیات کاربر در فرایندی با هویت واقعی همان کاربر انجام می‌شود.

```
make
sudo python3 admin.py install
sudo python3 -m unittest -v test_public
```

پس از تغییر کد C، `sudo python3 admin.py rebuild` را اجرا کنید. اسکلت اولیه کامپایل می‌شود، اما آزمون‌های عملکردی تا تکمیل منطق موفق نمی‌شوند. غیرفعال‌بودن `setuid` خطای محیط است؛ به‌عنوان عبور از آزمون شمرده نمی‌شود.

اجرای آزمون‌ها ترتیبی است. تغییر مجوز میان بررسی نهایی و خواندن رخ نمی‌دهد. خطای I/O، اجرای هم‌زمان، بازیابی پس از crash و شناسهٔ ناموجود خارج از دامنه‌اند. شناسهٔ معلوم، اختیار ایجاد نمی‌کند. اعطا و لغو مجوز و مشاهدهٔ وضعیت، عملیات ابزار آزمونِ مورد اعتماد هستند؛ کاربران به فایل‌های صف، داده و آرشیو دسترسی مستقیم ندارند. در adapter بومی، فقط یک نمونهٔ فعال از سرویس وجود دارد.

قالب عملیات، رابط backend و قرارداد JSON خروجی در `README.md` مشخص شده است. کد را برای labelهای مجاز و UIDهای تخصیص‌یافته در نصب بنویسید؛ عدد UID و محتوا را ثابت فرض نکنید.

تحویل و نمره

یک فایل فشرده شامل پوشهٔ دانشجو، پیاده‌سازی‌ها، فایل‌های ثابت بدون تغییر، `traces.json`، بذرها، خروجی probeها و شاهدهای کاهش‌یافته تحویل دهید. گزارش حداکثر دو صفحه باشد: منطق کنترل دسترسی، تفاوت دو نوع کاهش اختیار، استقلال مدل، شواهد اثر و یک حد اعتبار نتیجه.

در درس کوئرا به نشانی عضو شوید و فایل فشرده، گزارش و ویدیوی ۳ تا ۵ دقیقه‌ای را در صفحهٔ همین تمرین بارگذاری کنید.

```
sudo python3 run.py --seed 14050714 --traces 500
```

این فرمان باید آزمون‌های عمومی و آزمونگر حالت‌مند را اجرا کند. آزمونگر با `--backend MODULE` نیز اجرا می‌شود تا مدرس نسخه‌های ارزیابی را جایگزین کند. موفقیت در آزمون‌های عمومی به‌تنهایی کافی نیست.

بخش	نمره
سیاست C، هویت ثابت و حفظ عملیات مجاز	۰٫۱۵
اجرای واقعی setuid، کاهش اختیار و تحلیل توصیفگر	۰٫۱۰
مدل مستقل و مقایسهٔ تصمیم و اثر	۰٫۱۰
تولید دنباله و کاهش شاهد	۰٫۱۰
کشف نسخه‌های ندیده، نبود رد اشتباه و گزارش	۰٫۰۵
مجموع	۰٫۵۰

استفاده از LLM مجاز است؛ نام ابزار و بخش کمک‌گرفته‌شده را کوتاه در گزارش اعلام کنید. نمره بر اساس رفتار اجرا و شواهد آزمون تعیین می‌شود.